

CANLIFAL — FAZ 4 RAPORU

Rate Limiting (Hız Sınırlama) + Idempotency (Tekrar Koruması)

Tarih: 2026-08-27

Kapsam: Eklemeli (additive). Mevcut hiçbir uç kaldırılmadı, mevcut istek/yanıt sözleşmeleri değiştirilmedi.

1. Neden bu faz?

Faz 1 denetiminde tespit edilen kritik boşluklar:

Bulgu	Faz 1 durumu
Rate limit uygulanan handler sayısı	746 handler içinden yalnızca 9 (7 auth + hediye gönder + kayıt)
Idempotency (aynı isteğin iki kez işlenmesini engelleme)	Yalnızca 4 noktada, ad-hoc; ortak altyapı yok
Merkezî bucket/limit yönetimi	Yok — limitler kodun içine gömülü

Bu faz her iki eksiği de **ortak, yeniden kullanılabilir altyapı** haline getirdi.

2. Yeni dosyalar

Dosya	İçerik
lib/rate-limit-guard.ts	<pre>guardRateLimit(req, bucket, { userId, limit, windowMs, message }) → limit aşıldıysa hazır 429 yanıtı, aşılmadıysa null döner. Ayrıca DEFAULT_RATE_LIMITS, resolveLimit, getClientIp, resolveIdentity.</pre>
lib/idempotency.ts	<pre>getIdempotencyKey, beginIdempotent(req, scope, userId), completeIdempotent(recordId, status, body), releaseIdempotent(recordId).</pre>

2.1 Rate limit bucket'ları ve varsayılanları

Bucket	Varsayılan (istek/dk)
api_default	60
auth	10 (15 dakikalık pencere)
gift_send	10
chat_message	5
withdrawal	5
payment	10
stream_create	5
room_create	5
pk_create	10
agency_action	5

Limitler **kodda sabit değil**: `rate_limits` adlı Remote Config kaydından okunur (60 sn önbellekli). Yani admin panelinden değer değiştirilebilir, kod dağıtımı gerekmez. Config'te karşılığı olmayan bucket varsayılanı düşer.

2.2 429 yanıtındaki başlıklar

`Retry-After` , `X-RateLimit-Limit` , `X-RateLimit-Remaining` , `X-RateLimit-Reset` .

2.3 Idempotency çalışma mantığı

- İstemci `Idempotency-Key` (veya `X-Idempotency-Key`) başlığı gönderir.
- Başlık **yoksa** mekanizma tamamen devre dışıdır → mevcut istemciler (web + eski Flutter APK'lar) hiçbir değişiklik görmez.
- Aynı anahtarla ikinci istek gelirse ilk isteğin kaydedilmiş yanıtı aynen döner (yeni kayıt oluşmaz).
- İlk istek hâlâ işleniyorsa **409** döner; 60 saniyeden uzun süredir takılı kalmışsa kayıt bayat sayılıp yeniden denenmesine izin verilir.
- Kayıt TTL'i **24 saat**.
- Anahtar **doğrulamalardan sonra** rezerve edilir: hatalı bir istek anahtarı yakmaz, kullanıcı düzelterip aynı anahtarla tekrar deneyebilir.
- Hata durumunda `releaseIdempotent` kaydı serbest bırakır.
- Modül hiçbir koşulda exception fırlatmaz; altyapı hatası isteği düşürmez.

3. Şema değişikliği (eklemeli)

Yeni model `IdempotencyRecord` (`idempotency_records` tablosu):

Alan	Tip
id	String (cuid)
key	String @unique
scope	String
userId	String?
status	String (in_progress / completed)
responseStatus	Int?
responseBody	Json?
createdAt	DateTime
expiresAt	DateTime

İndeksler: `scope` , `userId` , `expiresAt` . Mevcut hiçbir tablo değiştirilmedi. Veritabanına başarıyla uygulandı.

Not: Bu veritabanı başka uygulamalarla paylaşıldığı için, diğer uygulamaların istemcilerini yeniden üretmesi gerekir.

4. Değiştirilen uçlar

4.1 Rate limit eklenenler (9 uç)

Uç	Bucket
POST /api/withdrawals	withdrawal
POST /api/payments/requests	payment
POST /api/chat/rooms/create	room_create
POST /api/video-streams	stream_create
POST /api/chat/rooms/[roomId]/pk	pk_create
POST /api/video-streams/pk	pk_create
POST /api/live/pk	pk_create
POST /api/agency/apply	agency_action
POST /api/agency/join	agency_action

Her kontrol **kimlik doğrulamadan sonra** çalışır, böylece kimlik başına (yoksa IP başına) sayım yapılır.

4.2 Idempotency eklenenler (2 uç — finansal)

Uç	Scope
POST /api/withdrawals	withdrawal
POST /api/payments/requests	payment_request

Bu iki uç seçildi çünkü çift gönderim doğrudan **para/bakiye hatası** üretir (çift para çekme talebi, çift ödeme kaydı).

5. Geriye dönük uyumluluk

Konu	Durum
Yeni uç eklendi mi?	Hayır — 478 path / 746 handler sayısı değişmedi
İstek gövdesi değişti mi?	Hayır
Yanıt gövdesi değişti mi?	Hayır (sadece yeni başlıklar eklendi)
Eski Flutter APK'lar etkilenir mi?	Hayır — Idempotency-Key göndermezler, mekanizma devre dışı kalır
Mevcut lib/rate-limiter.ts kullanıcıları	Dokunulmadı; 9 eski handler aynen çalışıyor. Yeni guard onun üzerine kuruldu.

6. Doğrulama

Kontrol	Sonuç
Tip kontrolü (tsc --noEmit)	✓ Hatasız
Üretim derlemesi	✓ Başarılı
Geliştirme sunucusu ayağa kalkıyor	✓
Şema veritabanına uygulandı	✓
Checkpoint kaydedildi	✓

Canlı 429 / 409 davranışı **uçtan uca çalıştırılarak test edilmedi** — kimlik doğrulaması gerektiren uçlar olduğu için gerçek oturum tokeni ile manuel deneme yapılmadı. Kod derlendi ve mantık gözden geçirildi.

7. Faz 5 önerisi — Ledger + AuditLog

Faz 1 denetiminde eksik olduğu belirlenen modeller: `Ledger` , `AuditLog` , `Role/Permission` , `Support-Ticket` , `Verification` , `Team` , `SupporterLevel` , `EffectRule` .

Öncelik önerisi: **değiştirilemez (immutable) Ledger + AuditLog**.

Neden	Açıklama
Finansal doğruluk	Şu anda jeton/CFC hareketleri farklı tablolara dağılmış durumda; tek bir değiştirilemez defter yok. Bakiye uyumsuzluğu çıktığında kaynak tespit edilemiyor.
Denetlenebilirlik	Admin işlemleri (bakiye ekleme, ban, ödeme onayı) merkezî bir denetim kaydına yazılmıyor.
Faz 4 ile uyum	Idempotency + Ledger birlikte çift-harcama korumasını tamamlar.

Planlanan içerik: `LedgerEntry` modeli (çift kayıt mantığı, sadece ekleme), `AuditLog` modeli, `lib/ledger.ts` yazma yardımcıları, mevcut kritik para hareketlerinin ledger'a **paralel** yazılması (mevcut tablolar bozulmadan), admin denetim görüntüleme sayfası.